

CyberSec2026 – Spring Cloud Gateway RCE Lab Handleiding

CVE-2022-22947 – Spring Cloud Gateway Remote Code Execution

Inhoudsopgave

1. Introductie
 2. Architectuur
 3. Prerequisites
 4. Repository installatie
 5. VirtualBox configuratie
 6. VM Deployment
 7. Victim Server Setup
 8. Kali Attacker Setup
 9. Exploit uitvoeren
 10. Exploit loop demonstratie
 11. Patch / Fix demonstratie
 12. Troubleshooting
 13. Security Analyse
-

1. Introductie

Deze labo-omgeving demonstreert de kwetsbaarheid:

- **CVE-2022-22947**
- Spring Cloud Gateway Remote Code Execution (RCE)
- SpEL Injection via exposed actuator endpoints

De omgeving bestaat uit:

- Een kwetsbare Debian target VM
 - Een Kali Linux attacker VM
 - Een geïsoleerd intern netwerk
-

2. Architectuur

Netwerk

VM	RoI	IP
Debian 12	Victim	192.168.56.10
Kali Linux	Attacker	192.168.56.20

Componenten

Victim

- Debian 12
- Java 17
- Maven
- Spring Cloud Gateway 3.1.0
- Open actuator endpoints

Attacker

- Kali Linux
- Python3
- requests library
- Exploit scripts

3. Prerequisites

Software

[VirtualBox](#)

[Osboxes Debian](#)

[Kali Linux VirtualBox image](#)

[Git](#)

4. Repository installatie

1. Clone de repository in je gekozen projectfolder

```
git clone https://github.com/SanderSchepers1993/CyberSec2026
```

2. Open Visual Studio Code
 3. Open de repository in Visual Studio Code.
-

5. VirtualBox configuratie

VBoxManage toevoegen aan PATH

Controleer:

```
VBoxManage --version
```

Indien VBoxManage niet gevonden kan worden:

1. Open Environment Variables
2. Voeg volgende map toe aan PATH:

```
C:\Program Files\Oracle\VirtualBox
```

6. VM Deployment

Start de VM installatie

Voer vanuit de root directory uit:

```
./01_create_vms.ps1
```

Dit script:

- maakt de VM's aan
- configureert netwerkadapters
- koppelt shared folders
- configureert VirtualBox instellingen

7. Victim Server Setup

Victim installatie

Start je VM op in VirtualBox

1. Log in met:
 - username: osboxes

- password: osboxes.org
2. Open een terminal
 3. Test of je een werkende internetverbinding hebt.

```
ping 8.8.8.8
```

- Indien je ping niet succesvol is, controleer of je NAT interface aanstaat.
4. Update je OS

```
sudo apt-get update
```

5. Installeer Git

```
sudo apt install -y git
```

6. Kloon je configuratiebestanden voor Kali

```
git clone https://github.com/SanderSchepers1993/CyberSec2026.git
```

7. Ga naar de nieuw gekloonde Victim directory

```
cd CyberSec2026/Victim
```

8. Voer het script 01_setup_server.sh uit met sudo privileges

```
sudo bash 01_setup_server.sh
```

- Indien je problemen hebt met openjdk-11-jdk, zie TROUBLESHOOTING onderaan deze README.
9. Ga verder met de postinstallatie van de [Attacker VM](#)

[TROUBLESHOOTING]

Unable to locate package openjdk-11-jdk

 Unable to find openjdk11

1. Voer het script 02_setup_server_java17.sh uit met sudo privileges

```
sudo bash 02_setup_server_java17.sh
```

2. Open je spring-gateway service met een teksteditor:

```
sudo nano /etc/systemd/system/spring-gateway.service
```

2. Vervang ExecStart door het volgende

```
ExecStart=/usr/bin/java --add-opens java.base/java.lang=ALL-UNNAMED -jar  
/opt/spring-gateway/target/vulnerable-gateway-1.0.0.jar
```

- We maken nu de omgeving met Java 17 i.p.v. Java 11.
- Java 17 blokkeert standaard het uitvoeren van externe java libraries.
- Met het bovenstaande commando laat je java libraries buiten de Java-module toe om via reflection in java.lang te kijken.

3. Herstart de service

```
sudo systemctl daemon-reload  
sudo systemctl restart spring-gateway.service
```

8. Kali Attacker Setup

Attacker installatie

Start je VM op in VirtualBox

1. Log in met:

- username: kali
- password: kali

1. Open een terminal

2. Test of je een werkende internetverbinding hebt.

```
ping 8.8.8.8
```

[OPTIONEEL] Update naar laatste nieuwe release

```
sudo apt-get update
```

2. Kloon je configuratiebestanden voor Kali

```
git clone https://github.com/SanderSchepers1993/CyberSec2026.git
```

3. Ga naar de nieuw gekloonde Attacker directory

```
cd CyberSec2026/Attacker
```

4. Voer kali_setup.sh uit met sudo privileges

```
sudo bash 01_kali_setup.sh
```

5. Je bent nu klaar om [de exploit](#) uit te voeren!

9. Exploit uitvoeren

Enkelvoudige exploit

```
python3 02_exploit.py \  
  --target http://192.168.56.10:8080 \  
  --cmd "id"
```

Exploit loop demonstratie

Start exploit loop

```
bash 03_exploit_loop.sh \  
  http://192.168.56.10:8080
```

Wat doet de loop?

Het script voert meerdere commando's uit:

```
whoami  
id  
hostname  
uname -a  
cat /etc/passwd
```

Interactieveodus

Na afloop kan een gebruiker zelf commando's uitvoeren.

Voorbeeld:

```
shell> ls -la /opt
```

12. Patch / Fix demonstratie

Probleem

Spring Cloud 2021.0.0 is kwetsbaar.

Versie 2021.0.1 bevat al een patch.

Fix toepassen

Open:

```
sudo nano /opt/spring-gateway/pom.xml
```

Wijzig Spring Cloud versie

Van:

```
<version>2021.0.0</version>
```

Naar:

```
<version>2021.0.1</version>
```

Wijzig Spring Boot versie

Van:

```
<version>2.6.1</version>
```

Naar:

```
<version>2.6.3</version>
```

Rebuild uitvoeren

```
sudo mvn clean package -DskipTests
```

Service herstarten

```
sudo systemctl restart spring-gateway
```

13. Troubleshooting

VBoxManage niet gevonden

Probleem

```
VBoxManage : command not found
```

Oplossing

Voeg VirtualBox toe aan PATH.

VBoxSDS service disabled

Probleem

```
The VBoxSDS windows service is disabled
```

Oplossing

```
sc config VBoxSDS start=demand
```

Actuator niet bereikbaar

Controle

```
systemctl status spring-gateway
```

Logs

```
journalctl -u spring-gateway -n 100 --no-pager
```

exploit_loop.sh geeft geen output

Controleer:

- draait de service?
 - juiste IP?
 - actuator bereikbaar?
 - werkt 02_exploit.py afzonderlijk?
-

Netwerkproblemen

Ping testen

```
ping 192.168.56.10
```

Controleer interfaces

```
ip addr
```

Controleer internal network

Beide VM's moeten:

- op hetzelfde internal network zitten
- correct geconfigureerde adapter hebben

14. Security Analyse

Waarom werkt deze exploit?

De applicatie:

- stelt actuator endpoints beschikbaar
- valideert SpEL expressies onvoldoende
- evalueert user-controlled input

Gevaarlijke configuraties

Open actuator exposure

```
include: "*"
```

Geen security

```
enabled: false
```

Mitigaties

Update Spring Cloud

Gebruik:

```
2021.0.1+
```

Beperk actuator exposure

```
include: health,info
```

Gebruik authenticatie

- Spring Security
 - netwerksegmentatie
 - reverse proxy filtering
-